

Modelo de Encuesta Integral de Madurez en Ciberseguridad (Alineada con GCI)

Propósito

Esta encuesta pretende evaluar la madurez de tu organización en ciberseguridad siguiendo la lógica de los cinco pilares del Global Cybersecurity Index (GCI) de la UIT: medidas **jurídicas, técnicas, organizativas**, de **desarrollo de capacidades** y de **cooperación**.^[web:28]^[web:33]

Tu sinceridad es oro; el maquillaje es para los informes públicos, no para las mejoras internas.

0. Datos generales de la organización

0.1. Perfil básico

1. Tamaño de la organización (personas empleadas)
2. ☐ Micro (1–9)
3. ☐ Pequeña (10–49)
4. ☐ Mediana (50–249)
5. ☐ Grande (250–999)
6. ☐ Muy grande (≥ 1.000)
7. Sector principal de actividad (selecciona el más relevante)
 8. ☐ Administración pública
 9. ☐ Salud
 10. ☐ Energía
 11. ☐ Agua y medio ambiente
 12. ☐ Transporte y logística
 13. ☐ Finanzas y seguros
 14. ☐ Industria / manufactura
 15. ☐ TIC / servicios digitales
 16. ☐ Educación / investigación
 17. ☐ Otros (especificar): ____
18. Localización principal
 19. ☐ España – ámbito nacional
 20. ☐ España – principalmente autonómico / local
 21. ☐ Multinacional con presencia significativa en España
22. ¿La organización está sujeta a alguna de estas normativas/figuras?
 23. ☐ NIS2 (operador esencial / importante)
 24. ☐ ENS (Esquema Nacional de Seguridad)
 25. ☐ RGPD / LOPD-GDD
 26. ☐ Sector financiero (EBA, DORA, etc.)

27.

☐ Otros marcos (ISO 27001, NIST CSF, etc.)

28.

Rol de la persona que responde

29. ☐ CISO / Responsable de Seguridad de la Información

30. ☐ CIO / CTO / Director de Tecnología

31. ☐ Responsable de Cumplimiento / Legal

32. ☐ Responsable de Operaciones / Riesgos

33. ☐ Otro (especificar): ____

☐ Muy grande (≥ 1.000)

Sector principal de actividad (selecciona el más relevante)

☐ Otros (especificar): ____

Localización principal

☐ Multinacional con presencia significativa en España

¿La organización está sujeta a alguna de estas normativas/figuras?

☐ Otros marcos (ISO 27001, NIST CSF, etc.)

Rol de la persona que responde

1. Pilar Jurídico (Legal)

Aquí miramos si tu organización vive en el siglo XXI jurídico o sigue en la edad de piedra digital.

1.1. Cumplimiento normativo general

34. ¿Existe un inventario actualizado de normativas aplicables en materia de ciberseguridad y protección de datos?

35. ☐ No existe

36. ☐ Existe de forma informal (documentos dispersos, no sistemático)

37. ☐ Existe formalmente, pero se revisa de manera esporádica

38. ☐ Existe, se revisa al menos anualmente

39.

☐ Existe, se revisa periódicamente y se vincula a un mapa de riesgos

40.

¿Se ha realizado en los últimos 24 meses un análisis de brechas de cumplimiento (gap analysis) frente a las normativas aplicables?

41. ☐ No

42. ☐ Sí, de manera parcial o puntual

43. ☐ Sí, completo pero sin plan formal de remediación

44. ☐ Sí, completo y con plan de remediación en marcha

45.

☐ Sí, y se monitoriza el avance con indicadores y reporte periódico

46.

¿Cuál es el nivel de integración entre cumplimiento de protección de datos y ciberseguridad?

47. ☐ Independientes, casi sin interacción

48. ☐ Coordinación esporádica (reuniones ad hoc)

49. ☐ Coordinación frecuente (reuniones periódicas y proyectos conjuntos)

50. ☐ Integración alta (modelo de gobierno común, KPIs compartidos)

☐ Existe, se revisa periódicamente y se vincula a un mapa de riesgos

¿Se ha realizado en los últimos 24 meses un análisis de brechas de cumplimiento (gap analysis) frente a las normativas aplicables?

☐ Sí, y se monitoriza el avance con indicadores y reporte periódico

¿Cuál es el nivel de integración entre cumplimiento de protección de datos y ciberseguridad?

1.2. Ciberdelito, evidencia digital y contratos

51. ¿Se han definido procedimientos internos para la preservación de evidencias digitales ante incidentes?
52. ☐ No, se improvisa según el caso
53. ☐ Sí, pero no están documentados
54. ☐ Sí, documentados pero poco conocidos
55. ☐ Sí, documentados, conocidos y probados en simulacros
56. ¿Los contratos con proveedores TIC y de nube incluyen cláusulas específicas de ciberseguridad (SLAs de seguridad, notificación de incidentes, auditorías)?
57. ☐ No lo sabemos / no se revisa
58. ☐ Se incluye de forma genérica, sin requisitos medibles
59. ☐ Se incluyen requisitos básicos (cifrado, backups, notificación de incidentes)
60. ☐ Se incluyen requisitos avanzados (pruebas, auditorías, métricas)
61. ☐ Existe un marco estándar de cláusulas de ciberseguridad aplicado de forma sistemática
62. ¿Se ha formado al equipo jurídico / compras en aspectos de ciberseguridad contractual?
63. ☐ No
64. ☐ Formación puntual o informal
65. ☐ Programa formativo estructurado y recurrente
- ☐ Sí, documentados, conocidos y probados en simulacros

¿Los contratos con proveedores TIC y de nube incluyen cláusulas específicas de ciberseguridad (SLAs de seguridad, notificación de incidentes, auditorías)?

☐ Existe un marco estándar de cláusulas de ciberseguridad aplicado de forma sistemática

¿Se ha formado al equipo jurídico / compras en aspectos de ciberseguridad contractual?

2. Pilar Técnico (Technical)

Ahora hablamos de máquinas, cables, logs y esa sensación de que el SIEM canta más que un canario en primavera.

2.1. Inventario de activos y arquitectura

66. ¿Existe un inventario actualizado de activos de información (hardware, software, datos, servicios en nube)?

67. ☐ No existe

68. ☐ Existe, pero desactualizado (> 12 meses)

69. ☐ Existe y se actualiza al menos anualmente

70.

☐ Existe y se actualiza de forma continua/automatizada

71.

¿Cómo describirías la segmentación de red y el enfoque Zero Trust?

72. ☐ Red plana, confianza casi ilimitada en la red interna

73. ☐ Segmentación básica (por zonas o VLAN) sin políticas granulares

74. ☐ Segmentación media con controles por tipo de servicio / usuario

75. ☐ Principios de Zero Trust parcialmente implantados (MFA, micro-segmentación en áreas críticas)

76.

☐ Modelo Zero Trust definido y desplegado de forma sistemática

77.

¿Se dispone de un inventario de servicios en nube (SaaS, PaaS, IaaS) aprobado y gobernado?

78. ☐ No, uso de nube mayoritariamente “sombra”

79. ☐ Parcialmente, con inventarios manuales

80. ☐ Sí, inventario formal, con evaluación de riesgos y clasificación de servicios

☐ Existe y se actualiza de forma continua/automatizada

¿Cómo describirías la segmentación de red y el enfoque Zero Trust?

☐ Modelo Zero Trust definido y desplegado de forma sistemática

¿Se dispone de un inventario de servicios en nube (SaaS, PaaS, IaaS) aprobado y gobernado?

2.2. Protección, detección y respuesta

81. ¿Qué capacidades de monitorización y detección tiene la organización?
82. ☐ Protección básica (antivirus, firewall perimetral) sin monitorización centralizada
83. ☐ Monitorización limitada (logs en algunos sistemas críticos)
84. ☐ SIEM/SOC parcial (solo sistemas clave)
85. ☐ SOC interno / externo que cubre la mayoría de activos críticos
86. ☐ SOC maduro 24x7 con casos de uso avanzados (detección de comportamiento, UEBA, etc.)
87. ¿Se usan tecnologías de automatización (SOAR, scripts, playbooks) para la respuesta a incidentes?
88. ☐ No
89. ☐ Sí, de forma experimental o para algunos casos concretos
90. ☐ Sí, integrado en procesos estándar de respuesta
91. ¿Qué cobertura de copias de seguridad existe para datos críticos?
92. ☐ Copias manuales o esporádicas
93. ☐ Copias regulares, pero sin pruebas de restauración
94. ☐ Copias regulares con pruebas de restauración puntuales
95. ☐ Estrategia 3-2-1 (o equivalente), con pruebas de restauración periódicas documentadas
- ☐ SOC maduro 24x7 con casos de uso avanzados (detección de comportamiento, UEBA, etc.)
- ¿Se usan tecnologías de automatización (SOAR, scripts, playbooks) para la respuesta a incidentes?
- ☐ Sí, integrado en procesos estándar de respuesta
- ¿Qué cobertura de copias de seguridad existe para datos críticos?

2.3. OT/ICS y tecnologías emergentes

96. ¿La organización opera sistemas OT/ICS (plantas industriales, energía, transporte, etc.)?

97. ☐ No aplica

98. ☐ Sí, pero sin medidas específicas de ciberseguridad OT

99. ☐ Sí, con medidas básicas y revisión periódica

100.

☐ Sí, con arquitectura OT segmentada, políticas específicas y auditorías periódicas

101.

Respecto al uso de Inteligencia Artificial y analítica avanzada:

102. ☐ No se utiliza IA de forma relevante

103. ☐ Se utilizan casos aislados sin evaluación de riesgos específica

104. ☐ Existe un inventario y evaluación de riesgos de casos de uso de IA

105. ☐ Existe un marco de gobernanza de IA (políticas, controles, revisión periódica)

☐ Sí, con arquitectura OT segmentada, políticas específicas y auditorías periódicas

Respecto al uso de Inteligencia Artificial y analítica avanzada:

3. Pilar Organizativo (Organizational)

Aquí miramos si la ciberseguridad tiene silla en la mesa... o si se conforma con una taburete al fondo.

3.1. Estrategia y gobierno

106. ¿Existe una estrategia o plan director de ciberseguridad alineado con la estrategia de negocio?

107. ☐ No

108. ☐ Sí, pero informal / no aprobado

109. ☐ Sí, formalmente aprobado, pero poco conocido

110.

☐ Sí, aprobado, comunicado y revisado al menos cada 2–3 años

111.

¿Quién es el máximo responsable de ciberseguridad?

112. ☐ No hay una figura definida

113. ☐ Responsable de TI con rol parcial en seguridad

114. ☐ CISO / Responsable de Seguridad reportando a TI

115.

☐ CISO / Responsable de Seguridad reportando a dirección general / consejo

116.

Frecuencia de reporte de ciberseguridad al máximo órgano de gobierno (dirección, consejo, patronato)

117. ☐ Nunca o solo ante incidentes graves

118. ☐ Al menos una vez al año

119. ☐ Varias veces al año (trimestral o superior)

120. ☐ Existe un cuadro de mando periódico con indicadores de riesgos, incidentes, inversiones y ROI

☐ Sí, aprobado, comunicado y revisado al menos cada 2–3 años

¿Quién es el máximo responsable de ciberseguridad?

☐ CISO / Responsable de Seguridad reportando a dirección general / consejo

Frecuencia de reporte de ciberseguridad al máximo órgano de gobierno (dirección, consejo, patronato)

3.2. Gestión de riesgos y continuidad

121. ¿Se integra la ciberseguridad en el marco de gestión de riesgos corporativos?

122. ☐ No, se trata como asunto técnico aislado

123. ☐ Identificación básica de riesgos TIC

124. ☐ Mapa de riesgos de ciberseguridad con priorización básica

125.

☐ Mapa de riesgos integrado con riesgos operativos y financieros

126.

¿Existen planes de continuidad de negocio (BCP) y recuperación ante desastres (DRP) que incluyan escenarios de ciberincidente?

127. ☐ No

128. ☐ Sí, pero sin pruebas específicas de ciberincidentes

129. ☐ Sí, con pruebas parciales (ejercicios de escritorio, pruebas técnicas limitadas)

130.

☐ Sí, con ejercicios regulares, incluyendo simulacros integrales con negocio

131.

¿Cuál es el nivel de formalización del proceso de gestión de incidentes?

132. ☐ No existe proceso definido

133. ☐ Proceso informal, sin documentación

134. ☐ Proceso documentado, conocido por el equipo de TI

135. ☐ Proceso documentado, conocido por las áreas de negocio relevantes, probado en simulacros

☐ Mapa de riesgos integrado con riesgos operativos y financieros

¿Existen planes de continuidad de negocio (BCP) y recuperación ante desastres (DRP) que incluyan escenarios de ciberincidente?

☐ Sí, con ejercicios regulares, incluyendo simulacros integrales con negocio

¿Cuál es el nivel de formalización del proceso de gestión de incidentes?

4. Pilar Desarrollo de Capacidades (Capacity Development)

Sin personas formadas, la mejor tecnología es solo decoración cara.

4.1. Formación y concienciación

136. ¿Existe un programa formal de formación en ciberseguridad para empleados?

137. ☐ No

138. ☐ Sesiones puntuales o “charlas” ocasionales

139. ☐ Programa anual básico (e-learning, comunicaciones, etc.)

140.

☐ Programa estructurado por perfiles (dirección, TI, negocio, usuarios privilegiados)

141.

¿Se realizan campañas de concienciación y simulacros de phishing u otros ataques de ingeniería social?

142. ☐ No

143. ☐ Sí, de forma esporádica

144.

☐ Sí, de forma regular, con métricas y planes de mejora

145.

¿Existe formación específica para el equipo directivo y el consejo de administración en materia de ciberseguridad y riesgo tecnológico?

146. ☐ No

147. ☐ Sí, ocasional

148. ☐ Sí, se realiza al menos una vez al año

☐ Programa estructurado por perfiles (dirección, TI, negocio, usuarios privilegiados)

¿Se realizan campañas de concienciación y simulacros de phishing u otros ataques de ingeniería social?

☐ Sí, de forma regular, con métricas y planes de mejora

¿Existe formación específica para el equipo directivo y el consejo de administración en materia de ciberseguridad y riesgo tecnológico?

4.2. Talento y recursos

149. ¿Cómo describirías el dimensionamiento del equipo de ciberseguridad?

150. ☐ No existe equipo dedicado

151. ☐ 1–2 personas con rol parcial

152. ☐ Equipo pequeño dedicado (3–5 personas)

153.

☐ Equipo dedicado y multidisciplinar (> 5 personas)

154.

¿Cuál es el nivel de subcontratación de servicios de ciberseguridad?

155. ☐ Nulo o residual

156. ☐ Moderado (servicios específicos: auditoría, pentest, etc.)

157. ☐ Elevado (SOC, respuesta a incidentes, consultoría recurrente)

158.

☐ Modelo híbrido bien definido y gobernado

159.

¿La organización dispone de un plan de desarrollo profesional y certificaciones para perfiles de ciberseguridad?

160. ☐ No

161. ☐ Apoyo ad hoc, según presupuesto y demanda

162. ☐ Plan estructurado con objetivos y presupuesto anual

☐ Equipo dedicado y multidisciplinar (> 5 personas)

¿Cuál es el nivel de subcontratación de servicios de ciberseguridad?

☐ Modelo híbrido bien definido y gobernado

¿La organización dispone de un plan de desarrollo profesional y certificaciones para perfiles de ciberseguridad?

5. Pilar Cooperación (Cooperation)

La ciberseguridad es un deporte de equipo; jugar en solitario solo impresiona a los atacantes.

5.1. Cooperación externa

163. ¿La organización participa en redes o foros sectoriales de ciberseguridad?

164. ☐ No

165. ☐ Sí, con participación ocasional

166.

☐ Sí, con participación activa (grupos de trabajo, proyectos)

167.

¿Se comparte información sobre incidentes y amenazas con terceros de confianza (CSIRT, asociaciones, organismos públicos)?

168. ☐ No, solo se gestiona internamente

169. ☐ Sí, pero de forma limitada

170.

☐ Sí, de forma sistemática, con acuerdos y canales establecidos

171.

¿Se han realizado ejercicios conjuntos (ej. con proveedores críticos, clientes clave, autoridades) de gestión de ciberincidentes?

172. ☐ No

173. ☐ Sí, ejercicios puntuales

174. ☐ Sí, ejercicios regulares con lecciones aprendidas documentadas

☐ Sí, con participación activa (grupos de trabajo, proyectos)

¿Se comparte información sobre incidentes y amenazas con terceros de confianza (CSIRT, asociaciones, organismos públicos)?

☐ Sí, de forma sistemática, con acuerdos y canales establecidos

¿Se han realizado ejercicios conjuntos (ej. con proveedores críticos, clientes clave, autoridades) de gestión de ciberincidentes?

5.2. Cooperación interna

175. ¿Cómo valorarías la colaboración entre las áreas de TI, ciberseguridad, negocio y legal?

176. ☐ Fragmentada, cada uno con su agenda

177. ☐ Colaboración básica en proyectos puntuales

178. ☐ Colaboración estructurada (comités, canales formales, proyectos transversales)

179. ☐ Cultura de colaboración madura, con objetivos compartidos y co-responsabilidad

6. Inversión, ROI y percepción de riesgo

Aquí entramos en la parte delicada: el dinero, esa métrica universal del cariño empresarial.

180. ¿Qué porcentaje aproximado del presupuesto de TI se destina a ciberseguridad?

181. ☐ < 5 %

182. ☐ 5–10 %

183. ☐ 10–20 %

184. ☐ > 20 %

185.

☐ No se dispone del dato

186.

¿Cómo ha evolucionado el presupuesto de ciberseguridad en los últimos 3 años?

187. ☐ Ha disminuido

188. ☐ Se ha mantenido estable

189. ☐ Ha aumentado moderadamente (< 20 % acumulado)

190.

☐ Ha aumentado de forma significativa (≥ 20 % acumulado)

191.

¿Se evalúa el retorno de la inversión (ROI) o valor generado por la ciberseguridad?

192. ☐ No, se considera coste necesario

193. ☐ Sí, de forma cualitativa (reducción de riesgos, cumplimiento)

194.

☐ Sí, con métricas cuantitativas (pérdidas evitadas, reducción de incidentes, mejora de disponibilidad)

195.

En una escala del 1 al 5, ¿cuál es la percepción de la dirección sobre la criticidad de la ciberseguridad para el negocio?

196. ☐ 1 – Tema técnico secundario

197. ☐ 2 – Importante, pero no prioritario

198. ☐ 3 – Uno más de los riesgos relevantes

199. ☐ 4 – Factor crítico para la continuidad

200. ☐ 5 – Factor estratégico y diferenciador

☐ No se dispone del dato

¿Cómo ha evolucionado el presupuesto de ciberseguridad en los últimos 3 años?

☐ Ha aumentado de forma significativa (≥ 20 % acumulado)

¿Se evalúa el retorno de la inversión (ROI) o valor generado por la ciberseguridad?

[] Sí, con métricas cuantitativas (pérdidas evitadas, reducción de incidentes, mejora de disponibilidad)

En una escala del 1 al 5, ¿cuál es la percepción de la dirección sobre la criticidad de la ciberseguridad para el negocio?

7. Comentarios cualitativos

Espacio para que la realidad matice los checkboxes.

201.

Principales retos de ciberseguridad que ve su organización en los próximos 2–3 años:

Respuesta abierta

202.

Tres cambios que más ayudarían a mejorar la ciberseguridad en su organización:

Respuesta abierta

Principales retos de ciberseguridad que ve su organización en los próximos 2–3 años:

Respuesta abierta

Tres cambios que más ayudarían a mejorar la ciberseguridad en su organización:

Respuesta abierta